

SIMATS ENGINEERING

Department of Computer Science and Engineering

ASSESSMENT TOOL 3 – CASE STUDY

Student Name	Pranov Raaj G
Register Number	192372355
Course Code	ITA14 — Ethical Hacking

Note on Sources

The five responses below are developed from the CO4 Assessment Tool 3 case study brief. Where current secure-development guidance is referenced for defensive best practices, OWASP recommendations have been used.

Question 1 — Apache Web Server Security Assessment

Case Summary

An e-commerce company's Apache server on Linux shows unauthorized transactions, suspicious HTTP requests, hidden-directory probing, malicious script injection, an outdated Apache version, and no Web Application Firewall.

1. Possible Attack Vectors

- Directory traversal exposing configuration and backup files.
- Cross-Site Scripting (XSS) through unsanitized input fields.
- SQL Injection against login or transaction forms.
- Exploitation of known CVEs in the outdated Apache version.
- Absence of a Web Application Firewall allowing malicious traffic through unfiltered.

2. Assessment Methodology (Kali Linux)

1. Reconnaissance — Nmap, WhatWeb, and Nikto to fingerprint the server and services.
2. Directory enumeration — Gobuster to discover hidden paths and files.
3. Web application assessment — Burp Suite to intercept and analyze requests.
4. Vulnerability validation — SQLmap to confirm SQL injection, strictly within an authorized test environment.

3. Example Assessment Commands

```
nmap -sV -A target-ip
whatweb http://target-ip
nikto -h http://target-ip
gobuster dir -u http://target-ip -w wordlist.txt
sqlmap -u "http://target/login?id=1"
```

4. Layered Defense Strategy

- Update Apache to the latest stable version and disable unnecessary modules.
- Remove default files and enforce least-privilege file permissions.

- Deploy a Web Application Firewall in front of the server.
- Use parameterized queries and consistent output encoding.
- Monitor logs continuously with a SIEM solution and rate-limit with Fail2Ban.

Question 2 — SQL Injection and XSS Security Audit

Case Summary

A financial services web application allows login, account viewing, and transactions. Penetration testing found it vulnerable to SQL injection and XSS; error messages leak database structure and inputs are not sanitized.

1. How the Vulnerabilities Are Exploited

Because user input is not validated, an attacker can inject SQL syntax into form fields to manipulate backend queries, while unsanitized fields also allow malicious scripts to be stored or reflected back to other users' browsers. Verbose error messages further expose database structure, making exploitation easier.

2. Audit Methodology (Kali Linux)

5. Intercept requests and responses with Burp Suite Proxy.
6. Identify injectable parameters across forms and URL query strings.
7. Validate SQL injection with SQLmap against the identified parameters.
8. Test XSS payloads using Burp Repeater and Intruder.
9. Re-test after remediation to confirm stored and reflected scripts no longer execute.

3. Impact on the CIA Triad

- Confidentiality — customer records and account data can be exposed.
- Integrity — transaction data may be altered without authorization.
- Availability — malicious queries or scripts can disrupt normal service.

4. Mitigation Strategy (OWASP-Aligned)

- Use prepared statements / parameterized queries for all database access.
- Apply allow-list based input validation.
- Configure secure session cookies — HttpOnly, Secure, and SameSite attributes.
- Implement a Content Security Policy and consistent output encoding.

Question 3 — Evil Twin Wireless Attack Analysis

Case Summary

A corporate WPA2-PSK network experienced unusual login prompts and slow performance. Investigation revealed a rogue Evil Twin access point mimicking the official SSID, used to capture credentials and perform man-in-the-middle attacks.

1. How the Attack Was Executed

The attacker cloned the legitimate SSID and broadcast it from a stronger or nearer rogue access point. Employee devices auto-connected to the familiar network name, allowing the attacker to intercept credentials and traffic in a classic man-in-the-middle position.

2. Detection with Kali Linux Tools

- Aircrack-ng — scan for duplicate SSIDs and suspicious BSSIDs.
- Wireshark — inspect beacon, authentication, and association frames for anomalies.

3. Weaknesses in the Existing Configuration

- WPA2-PSK only, with a shared key and no per-user authentication.
- No rogue access point detection in place.
- No certificate-based validation of the network.

4. Recommended Countermeasures

- Migrate to WPA3 or WPA2/WPA3-Enterprise with 802.1X authentication.
- Deploy a Wireless Intrusion Detection System (WIDS).
- Continuously monitor for rogue access points.
- Run regular user-awareness training on Evil Twin and phishing risks.

Question 4 — Wireless-to-Web-Application Attack Chain**Case Summary**

An internal employee management system is accessible over Wi-Fi secured with weak passwords, and the web application lacks proper authentication and session management. An attacker compromised the Wi-Fi, then exploited the web application to escalate privileges and access confidential data.

1. Attack Chain

10. Wi-Fi compromise — weak pre-shared key cracked or guessed.

11. Reconnaissance — host discovery with Netdiscover.
12. Scanning — service and port enumeration with Nmap.
13. Web application enumeration — directory and endpoint discovery.
14. Exploitation — weak authentication bypassed.
15. Session hijacking — poorly managed session tokens reused.
16. Privilege escalation — elevated access to confidential employee data.

2. Kali Linux Tools by Phase

- Netdiscover — identify live hosts on the wireless network.
- Nmap — port and service scanning.
- Gobuster — web directory and file enumeration.
- Burp Suite — authentication and session testing.
- SQLmap — database-layer exploitation, where applicable.
- Wireshark — traffic capture and analysis.

3. Defense-in-Depth Framework

- Upgrade wireless security to WPA3.
- Enforce strong, regularly rotated passwords.
- Add multi-factor authentication (MFA) for the web application.
- Apply role-based access control (RBAC).
- Maintain a disciplined patch-management schedule.
- Deploy IDS and SIEM monitoring across both network layers.

Question 5 — Deauthentication Attack Analysis

Case Summary

A university campus experiences frequent Wi-Fi disruptions during peak hours caused by repeated deauthentication attacks against access points, disconnecting legitimate users and causing denial of service.

1. How Deauthentication Attacks Work

The 802.11 management frame protocol allows deauthentication frames to be sent unauthenticated and unencrypted. An attacker spoofs these frames from an access point to connected clients (or vice versa), forcing repeated disconnections and effectively creating a denial-of-service condition.

2. Simulation and Analysis (Controlled Environment, Kali Linux)

- Aircrack-ng suite — identify target access points and associated clients.
- Wireshark — capture and inspect deauthentication management frames.

3. Impact on Availability and Productivity

- Repeated disconnection of legitimate users from network resources.
- Interrupted classes, online assessments, and administrative work.
- Reduced overall trust in campus network reliability.

4. Recommended Mitigations

- Enable Protected Management Frames (802.11w) to authenticate management traffic.
- Upgrade to WPA3, which mandates management-frame protection.
- Deploy a Wireless Intrusion Detection System to flag deauthentication floods.
- Keep access-point firmware up to date.
- Monitor and alert on abnormal volumes of deauthentication traffic.

Conclusion

Across all five cases, the recurring theme is that a single weak layer — an unpatched server, an unsanitized input field, a shared wireless key, or an unauthenticated management frame — is enough for an attacker to gain a foothold. A layered defense combining secure coding, disciplined patch management, strong wireless authentication, continuous monitoring, and user awareness gives the strongest practical protection for confidentiality, integrity, and availability.

References

17. CO4 Assessment Tool 3 — Ethical Hacking case study brief (course-provided).
18. OWASP SQL Injection Prevention Cheat Sheet — parameterized queries and allow-list validation.
19. OWASP Web Security Testing Guide — SQL injection and XSS testing methodology.

